

SECCIÓN 1.5



Ética, confidencialidad y responsabilidad

Temas de esta sección:

- Acceso a información sensible: manejo ético y seguro
- Protocolos de confidencialidad
- El rol del analista como primera línea de defensa
- Importancia del registro y la trazabilidad

1.5 | Acceso a información sensible: manejo ético y seguro



Los analistas tienen acceso a información extremadamente sensible: logs de usuarios, tráfico de red, configuraciones internas, credenciales comprometidas y datos personales o estratégicos del negocio. Ese nivel de acceso implica un nivel de responsabilidad igual de alto.

"Ver no significa tener permiso para divulgar"

Confidencialidad total	Uso estrictamente profesional	Evitar la curiosidad digital	Cumplimiento de políticas	Principio de mínimo privilegio
Nunca compartir información sensible fuera del entorno autorizado, ni con personas no involucradas.	Acceder a datos solo cuando es necesario para realizar una tarea asignada.	No explorar información 'por interés' si no hay un motivo profesional válido.	Seguir NDAs, normativas de la organización y cualquier marco legal aplicable.	Usar solo los accesos necesarios y no solicitar privilegios innecesarios.

Como analista L1, vas a ser muchas veces la primera persona que ve lo que otros no ven. De vos depende manejar esa información con seriedad, respeto y profesionalismo.

1.5 | Acciones permitidas vs. acciones prohibidas en el SOC



✓ ACCESO / ACCIÓN PERMITIDA	✗ ACCIÓN PROHIBIDA
✓ Ver logs como parte del análisis asignado	✗ Compartir capturas o logs por fuera del SOC
✓ Analizar un incidente que te fue asignado	✗ Comentar datos sensibles con amigos o en redes sociales
✓ Reportar hallazgos al equipo / Team Lead	✗ Investigar información por curiosidad personal
✓ Usar herramientas según el procedimiento establecido	✗ Copiar información a dispositivos externos no autorizados
✓ Escalar con contexto claro y documentado	✗ Acceder a información de otros equipos sin necesidad operativa

"Ser analista SOC no solo es detectar amenazas. Es también proteger la confianza de toda una organización."



Los protocolos de confidencialidad son el conjunto de normas y procedimientos que regulan cómo debe manejarse la información dentro de un SOC. Son necesarios porque el SOC es un entorno de **alta exposición informativa**: una mala práctica puede poner en riesgo la seguridad, el cumplimiento normativo y la reputación de la organización.

NDAs — Acuerdos de confidencialidad	Clasificación de la información	Reglas de acceso y mínimo privilegio
Firmados al ingresar al equipo. Establecen obligaciones legales sobre la información manejada.	Define qué es 'confidencial', 'interno' o 'público'. No toda la información tiene el mismo nivel de sensibilidad.	Se accede solo a lo necesario para la tarea. No se investiga ni explora información por curiosidad.
Control de dispositivos y medios	Canales autorizados de comunicación	Manejo de incidentes internos
Prohibido copiar datos a dispositivos externos, hacer capturas no autorizadas o reenviar info por canales no oficiales.	Toda información sensible debe compartirse únicamente por canales corporativos seguros y autorizados.	Si hay sospecha de violación de confidencialidad, el protocolo define cómo actuar, a quién informar y qué documentar.

1.5 | Importancia del registro y la trazabilidad



Registrar significa documentar todo lo que ocurre durante el ciclo de vida de una alerta o incidente. **Trazabilidad** es la capacidad de reconstruir cada paso del proceso para auditar, responder a reguladores o mejorar procedimientos.

Evita errores y repeticiones	Permite respuesta coordinada	Facilita auditorías y compliance	Protege al equipo y la organización	Mejora procesos y detecciones
Si el análisis no se documenta, el siguiente analista podría repetir el trabajo o pasar por alto un patrón ya identificado.	En un equipo 24/7, los turnos cambian constantemente. La única forma de mantener el contexto es a través de registros detallados.	Marcos como ISO 27001, GDPR y NIST exigen registros completos de incidentes de seguridad.	Si algo sale mal, el registro sirve para demostrar que se actuó con criterio y dentro del protocolo.	La revisión de registros permite encontrar cuellos de botella, detectar falsas alarmas frecuentes y afinar las reglas del SIEM.

¿Qué se registra normalmente?

- Hora de la alerta y quién la recibió
- Tipo de incidente y clasificación asignada
- Acciones tomadas (consultas, bloqueos, correlaciones)
- Herramientas utilizadas durante el análisis
- Justificación de las decisiones tomadas
- A quién se escaló, cuándo y con qué datos
- Resultado final y lecciones aprendidas